

DIGITAL PRODUCT

AP Agent Governance Framework

The rules that keep agents employable: ownership, SoD, untrusted input, evidence, release, incidents.

Accountability

Every agent has a human owner who can be named in an audit interview. A16 does not own the function. The Head of AP or delegate does.

Segregation of duties

Proposal preparer ≠ A12 reviewer identity ≠ payment releaser. An agent that drafts a supplier mail cannot also change the vendor master.

Least privilege

Read the objects the job needs. Write only the objects the current level allows. No inherited end-user tokens. Non-human identity in the IAM process.

Untrusted content

Invoices, emails, portals and statements may contain instructions. The agent's policy lives outside retrieved content. BANK-CHANGE never executes from the same channel that requested it.

Confabulation

Amounts, tax, bank accounts and vendor IDs must be copied from source fields or deterministic services — not generated. If the model cannot point to a field, it escalates.

Change and release

Prompts, rules, tolerances, models and workflows are versioned. Production changes need a test record and an owner. Rollback is a written step, not a hope.

Incidents

Unauthorised send, wrong vendor, duplicate pay, injection, data leak: severity, contain, notify, recertify, return the agent to Level 0 if critical.

NIST / ISO stance

We map to NIST AI RMF (Govern/Map/Measure/Manage) and ISO/IEC 42001 themes. We do not claim certified compliance. Ledger GOV-001, GOV-002.